



Phishing Awareness & Social Engineering Defense

Recognizing threats, identifying spoofed vectors, and securing the human layer

Cyber Security Internship — CodeAlpha



What is Social Engineering?

Exploiting human psychology rather than software flaws to manipulate people into compromising security.

Urgency

Creates pressure with arbitrary deadlines (e.g., "Account suspended within 24 hours").

Authority

Impersonates executives, legal, or IT to gain compliance.

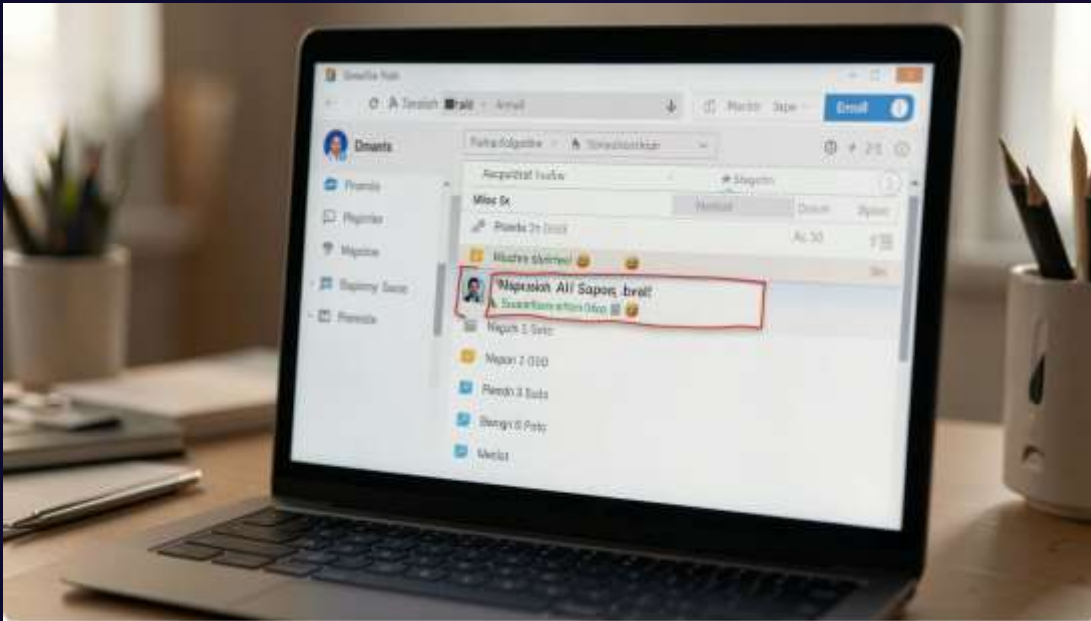
Fear & Intimidation

Threats of closure, fines, or lockout to force action.

Curiosity & Greed

Promises of incentives, bonuses, or exclusive updates to entice clicks.

Recognising Phishing Emails



- Sender header spoofing — look-alike domains and subtle typos (e.g., support@paypa1.com).
- Generic greetings — non-personal salutations like “Dear Customer”.
- Mismatched hyperlinks — displayed URL differs from actual destination.
- Malicious attachments — unexpected .docm, .zip, .rar, or ISO files.



Identifying Fake Websites



Typosquatting & Homographs

Characters replaced with visually identical Unicode (e.g., Cyrillic 'a').



Subdomain Deception

Addresses like login.bank.com.attacker-domain.net trick users.



HTTPS ≠ Trust

Padlock only means encrypted transit, not a legitimate host.



UI Inconsistencies

Low-res logos, broken links, and poor grammar signal fakes.

Real-World Case Studies



Case 1 — Business Email Compromise (BEC)

Attacker mimics CEO to request an immediate off-schedule vendor wire transfer.

Case 2 — Credential Harvesting Portal

Fake SSO login page prompts re-entry of Microsoft 365 or Google Workspace credentials.

Best Practices for Email Security



Enforce MFA

Require multi-factor authentication on all identity providers and mail accounts.



Inspect Links

Hover to verify actual destination before clicking.



Avoid Unknown Attachments

Do not open unsolicited macro-enabled or archive files from unknown senders.



Report Immediately

Use the enterprise "Report Phishing" button or notify SOC / IT Security promptly.



Interactive Knowledge Check



01

Q1

An email from "IT Security" asks you to click a link to verify your password before midnight.

Correct action: Do not click; verify the sender domain and report it to IT Security / SOC.

02

Q2

If a website shows a valid HTTPS padlock, is it guaranteed safe?

Correct action: No — attackers can obtain free SSL certificates for spoofed sites.



Keep vigilance high: the human layer is the last line of defence.